

SECURITY INTELLIGENCE // LARAVEL ECOSYSTEM // PUBLIC RELEASE

LARAVELHUNTER

v0.9.1 / EDGE-AWARE SECURITY ASSESSMENT ENGINE

محرك متخصص لتقييم تطبيقات Laravel: بصمة تقنية، تحليل
Filament و Livewire، ربط الإصدارات بالـ Advisories، فحص
مؤثق بالجلسات، مقارنة صلاحيات متعددة الأدوار، وتحليل واعٍ
للـ WAF/CDN مع وضع مختبر خاص للـ WAF.

AUTHORIZED USE ONLY

ما هي LaravelHunter؟

LaravelHunter هي أداة تقييم أمني مركزة على منظومة Laravel. هدفها تحويل التطبيق إلى صورة استخباراتية قابلة للتحليل: ما الإطار والمكونات؟ ما النسخة؟ ما الصفحات الإدارية الظاهرة؟ ما العمليات الحساسة؟ ما حدود التغطية؟ وأين يجب أن يركز الفاحص البشري؟

IDENTIFY

Framework Fingerprinting

تجمع إشارات Laravel و PHP و Filament و Livewire وتبني درجة ثقة بدلا من الاستنتاج من Header منفرد.

MAP

Surface Mapping

تزحف ضمن نفس الأصل وبطلبات GET محدودة لتصنيف صفحات الإدارة والResources والحقول والعمليات المرئية.

CORRELATE

Version & Advisory Intelligence

تربط النسخة الدقيقة أو القيود المحتملة بالAdvisories مع فصل حالة النسخة عن دليل Runtime.

COMPARE

Authorization Analysis

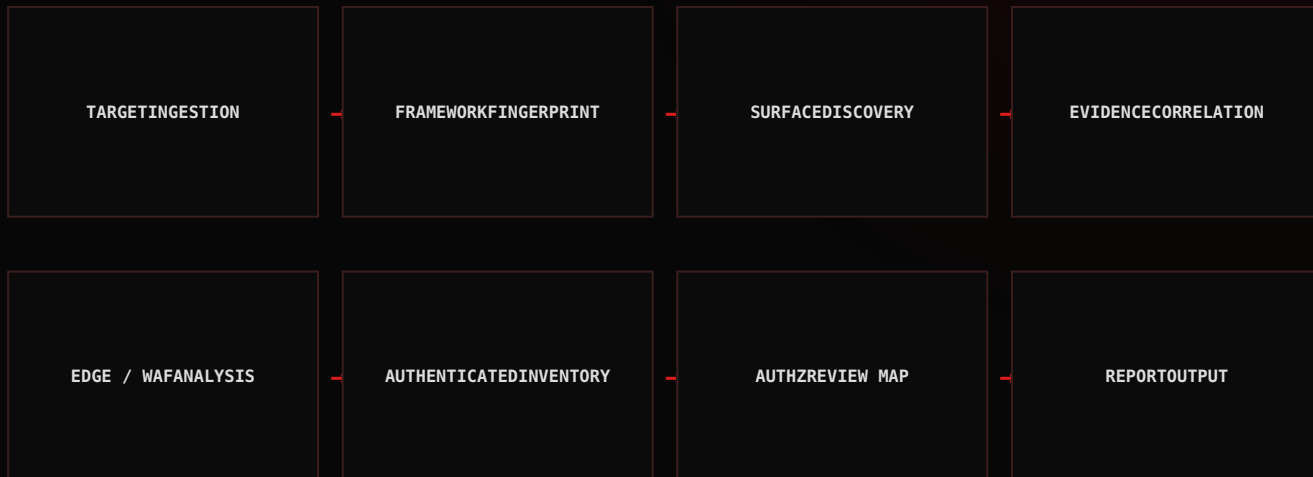
تدعم جلسات مصادقة متعددة لمقارنة الوصول والصفحات والعمليات بين أدوار مختلفة بدون تنفيذ عمليات تغيير حالة.

المبدأ: اجمع الدليل، اربطه بالسياق، ثم قرر.

نطاق الاستخدام: اختبارات مصرح بها، مختبرات محلية، أو برامج Bug Bounty ضمن النطاق. الأداة ليست محرك استغلال تلقائي ولا أداة تجاوز WAF عامة.

كيف تعمل الأداة؟

كل فحص يمر بسلسلة مراحل مترابطة. LaravelHunter لا تعتمد على مؤشر واحد؛ تجمع إشارات متعددة ثم ترفع أو تخفض الثقة حسب الأدلة التي رصدها.



STEP 01

Target & Redirect Context

تثبيت الهدف والـ Final URL والسياق التقني قبل أي استنتاج لاحق.

STEP 02

Evidence Fusion

دمج Headers, HTML markers, assets, paths و runtime indicators في نموذج ثقة.

STEP 03

Controlled Discovery

زحف bounded, same-origin, GET-only مع عدم استدعاء Livewire update endpoints كعمليات.

STEP 04

Operator Report

إخراج Markdown وJSON منظمين بحيث يمكن مراجعة الأدلة بدون أسرار الجلسة.

قاعدة: Detection لا يساوي Vulnerability. وجود Action مرئي لا يثبت Broken Authorization دون تحقق مخصص.

مصفوفة القدرات - v0.9.1

FRAMEWORK

Laravel / PHP Fingerprint

بصمة Laravel، إشارات redirects، PHP، ودرجة ثقة قابلة للتفسير.

COMPONENTS

Filament & Livewire

رصد runtime surfaces والassets والendpoints وتثبيت النسخ عند توفر دليل محلي.

VERSIONING

Exact / Constrained Version

تمييز النسخة الدقيقة عن القيود المرجحة، وعدم تقييم Advisory محدد عند غياب النسخة المطلوبة.

LOCAL MODE

Composer Correlation

قراءة composer.lock من مشروع تملكه محليا لإثبات نسخ Laravel و Filament و Livewire.

AUTH

Authenticated Scanning

استيراد Cookie/Header context من ملف محلي مع إبقاء القيم الحساسة خارج التقرير.

FILAMENT

Page / Action Analysis

تصنيف List/Create/View/Edit، حقول النماذج، Application Actions، و UI-state markers.

MATRIX

Multi-role Auth Matrix

مقارنة جليستين على المسارات والعمليات المرئية لإبراز فروقات تحتاج تحقق يدوي.

EDGE

WAF / CDN Awareness

اكتشاف Cloudflare ومؤشرات Edge أخرى، pacing، محافظ، وإيقاف safe-active عند challenge أو rate limit.

الاستخدام - من التثبيت إلى الفحص

1. تثبيت الأداة

```
$ cd LaravelHunter-v0.9.1
$ python3 -m venv .venv
$ source .venv/bin/activate
$ pip install -e .
```

2. فحص آمن

```
$ laravelhunter scan https://target.example/admin --safe-active
```

3. Local Project Mode

```
$ laravelhunter scan http://127.0.0.1:8000/admin \
--safe-active \
--project-path ~/Desktop/laravel-lab
```

4. فحص موثق بجلسة مصرح بها

```
$ laravelhunter scan http://127.0.0.1:8000/admin \
--safe-active \
--auth-file lab-auth.txt \
--project-path ~/Desktop/laravel-lab \
--max-discovery-pages 20
```

الجلسات: احفظ ملف الـ auth بصلاحيه 600، ولا تضيفه إلى Git، ولا تنسخ قيم Cookies / Tokens إلى التقارير.

Edge-Aware + WAF Laboratory

ابتداء من LaravelHunter v0.9، تتعامل مع الـ WAF/CDN كجزء من تغطية الفحص، لا كعائق يجب تجاوزه. يتم رصد الحماية وتعديل سلوك الفحص تلقائياً بشكل محافظ.

NORMAL	PACED-READ-ONLY	STOP-ACTIVE
--------	-----------------	-------------

الحالة	السلوك
normal	لا توجد إشارة حماية مؤثرة؛ يستمر safe-active ضمن حدوده.
paced-read-only	وجود WAF/CDN بدون block صريح؛ يتم تخفيض الوتيرة والإبقاء على طلبات قراءة محافظة.
stop-active	Challenge أو 429 أو block محمي؛ تتوقف probes النشطة والزحف الإضافي.

وضع مختبر WAF الخاص - v0.9.1

```
$ laravelhunter waf-lab http://127.0.0.1:8080/
```

```
Scope guard: loopback / RFC1918 / private only  
Method: benign GET-only differential corpus  
Output: edge-control vs application divergence
```

HARD GUARD

رفض الأهداف العامة

الأمر waf-lab يرفض أهداف الإنترنت العامة ويقبل loopback/private فقط.

DIFFERENTIAL

Normalization Signals

يقارن استجابات تمثيلات benign لنفس الطلب لانتقاط اختلاف بين الحافة والتطبيق.

حد واضح: لا Challenge solving، لا origin discovery، لا spoofing، لا payloads هجومية، ولا WAF bypass عام.

مقارنة الصلاحيات بين الأدوار

Auth Matrix تقارن جليستين مصرح بهما على نفس السطح. الأداة تعيد طلب صفحات GET فقط وتبرز الاختلافات في الوصول والعمليات المرئية بدون تنفيذ Delete/Create/Save.

```
$ laravelhunter auth-matrix http://127.0.0.1:8000/admin \  
--auth-a admin-auth.txt --label-a admin \  
--auth-b reviewer-auth.txt --label-b reviewer \  
--max-discovery-pages 20
```

Signal	Reviewer	Admin	Route
baseline	reachable	reachable	/admin/users
authorization difference	redirect / denied	reachable	/admin/users/create
authorization difference	redirect / denied	reachable	/admin/users/1/edit

المصفوفة لا تقول "هذه IDOR". بل تقول: "هنا اختلاف صلاحيات يستحق التحقيق."

- مقارنة reachability لكل مسار.
- مقارنة Application Actions المرئية.
- مقارنة Authorization review surfaces.
- إبقاء الحكم النهائي للفاحص.

كيف تقرأ النتائج؟

المؤشر	المعنى
Laravel confidence	درجة ترابط الأدلة التي تشير إلى Laravel؛ ليست مبنية على Header واحد فقط.
Exact Laravel version	نسخة مثبتة بدليل قوي مثل composer.lock المحلي؛ وإلا تبقى constrained أو unresolved.
Filament pages inventoried	عدد صفحات Filament التي تم جلبها وتحليل هويتها والحقول والعمليات الظاهرة فيها.
Authorization review surfaces	نقاط حساسة مثل create/edit/delete/save تحتاج مراجعة صلاحيات.
UI/state-only markers	عمليات داخلية أو واجهية ينبغي عدم خلطها مع Business Actions.
Version status	هل النسخة تقع ضمن نطاق Advisory أم لا، أو أن البيانات غير كافية للتقييم.
Runtime evidence	مؤشرات تدعم الصلة التقنية لكنها لا تثبت قابلية الاستغلال وحدها.
Edge-aware policy	كيف عدلت الأداة الوثيرة/safe-active بسبب WAF أو CDN.

```
Laravel version: 13.35.0 (exact)
Advisories evaluated: 3
Version status: not-affected-version
Runtime: not-observed
Edge-aware policy: normal
```

Interpretation:

Do not report a vulnerability when the installed version is outside the affected range.

مقاومة False Positives: عند غياب نسخة دقيقة أو دليل كاف، تعرض الأداة - not evaluated بدلا من الادعاء بوجود إصابة.

نتيجة اختبار الالاب الحالي

FRAMEWORK

13.35.0

Laravel Framework - exact from local composer.lock

ADMIN STACK

5.10.0

Filament - exact local version

RUNTIME

4.4.7

Livewire - exact local version

AUTH CONTEXT

200

Authenticated admin dashboard reachable in controlled lab

المسارات المكتشفة

- /admin/users/1/edit
- /admin/users/1
- /admin/users/create
- /admin/users
- /admin

Filament تحليل

Observed signals	Priority	Page
delete + authz review surface	HIGH	ListUsers
authorization review surfaces 2	HIGH	ViewUser
delete + save + 3 authz surfaces	HIGH	EditUser
create + UI-state marker	HIGH	CreateUser

Saved pages: 5
Route surfaces: 7
Filament pages inventoried: 5
Resource/page-correlated pages: 5
Authorization review surfaces: 8
UI/state-only action markers: 2
Edge-aware policy: normal

الحدود الأمنية المقصودة

قوة LaravelHunter تأتي من إبقاء الفحص قابلاً للسيطرة والتفسير. لذلك توجد حدود مقصودة تمنع تحويل الأداة إلى محرك استغلال أو تجاوز حماية تلقائي.

NO BLIND EXPLOIT

لا استغلال تلقائي

لا exploit chain تلقائي، لا Shell، ولا استخراج بيانات من الهدف.

GET-FIRST

اكتشاف منخفض المخاطر

الزحف يركز على GET و same-origin ولا يرسل Forms أو Actions لتغيير حالة التطبيق.

EDGE AWARE

كشف الحافة لا تجاوزها

الWAF/CDN يدخل في قرار التغطية والpacing؛ لا يتم تنفيذ evasion تلقائي على أهداف عامة.

LAB BOUNDARY

WAF Lab خاص

waf-lab مقيد تقنيا إلى loopback/private networks ويستخدم GET-only benign corpus.

REDACTION

حماية الأسرار

الجلسات محلية، والقيم الحساسة لا ينبغي أن تظهر في Markdown/JSON أو Git.

HUMAN VERDICT

القرار للفاحص

الأداة ترتب الأدلة ونقاط التحقيق؛ الفاحص يثبت الأثر ويحدد شدة الثغرة.

الخلاصة: LaravelHunter منصة **Assessment & Intelligence** مبنية لتقليل الضجيج وتحسين جودة القرار، لا لزيادة عدد الpayloads.

END OF DOSSIER // RELEASE SUMMARY

HUNT. MAP. VERIFY.

LaravelHunter v0.9.1 تجمع ما يحتاجه الفاحص في مسار واحد: اكتشاف، بصمة تقنية، نسخة، سطح إدارة، صلاحيات، Advisory correlation، ووعي بالWAF/CDN. الهدف ليس أن تبدو الأداة مخيفة فقط - بل أن تجعل الهدف أقل غموضا.

“لا تثق بالانطباع. اجمع الدليل، اربطه، ثم احكم.”

ZIP RELEASE

PDF DOSSIER

MARKDOWN / JSON REPORTS